AUDITORÍA

Contexto

Teniendo en cuenta los conceptos vistos en clase sobre la programación segura a la hora de desarrollar aplicaciones. Realiza la auditoría y la corrección de la aplicación C# de Gestión de usuarios y partidas.

PARTE 1 – Realización de la auditoría

Encuentra y documenta las vulnerabilidades existentes en la aplicación. Recuerda, que vuestro rol para realizar esta parte es de auditor de seguridad, no de desarrollador. A continuación, tenéis la ficha de auditoría a realizar para cada fallo detectado.

Fallo 1

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 9
Según los apuntes, ¿que antipatrón es?	Clave o contraseña escrita en el código (sección 4, Secretos). Los apuntes dicen que en una app cliente no hay secretos, porque lo que va dentro del ejecutable se puede extraer.
Si fueras un atacante, ¿cómo lo	Me descargo la aplicación, abro el .exe con un descompilador (en

utilizarías?	minutos se ve el texto de la clave) y ya tengo la clave del servidor. Con ella puedo enviar puntuaciones falsas o hacerme pasar por la aplicación.
Indica el nivel de gravedad: alto, medio, bajo	Alto

Fallo 2

Línea y fichero en el que está ubicado el error:	Program.cs, línea 19
Según los apuntes, ¿que antipatrón es?	Clave o contraseña escrita en el código (sección 4). Además, se enseña la contraseña a cualquiera que abra el programa.
Si fueras un atacante, ¿cómo lo utilizarías?	No necesito hacer nada: arranco la aplicación, leo en pantalla admin/admin1234, inicio sesión como administrador y entro al panel de administración.
Indica el nivel de gravedad: alto, medio, bajo	Alto

Fallo 3

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 10 y línea 31 (el envío)
Según los apuntes, ¿que antipatrón es?	Comunicar por HTTP (sección 6). Los apuntes dicen: “Siempre HTTPS, nunca HTTP”.
Si fueras un atacante, ¿cómo lo utilizarías?	Me pongo en la misma red wifi que el jugador y espío el tráfico. Como HTTP no va cifrado, leo el nombre del usuario, los puntos y la clave de API, y además puedo modificar la petición por el camino (por ejemplo añadirte puntos de partida).
Indica el nivel de gravedad: alto, medio, bajo	Alto

Fallo 4

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 28 y línea 30
Según los apuntes, ¿que antipatrón es?	Sección 8: Nunca registres contraseñas, tokens o datos personales (ni con Debug.Log ni con Console.WriteLine). También sección 4 (secretos).
Si fueras un atacante, ¿cómo lo utilizarías?	Miro por encima del hombro, una captura de pantalla o una pantalla compartida y ya tengo la clave completa. Las URL además suelen quedar guardadas en registros de servidores y de red.
Indica el nivel de gravedad: alto, medio, bajo	Medio

Fallo 5

Línea y fichero en el que está ubicado el error:	AuthService.cs, líneas 63-67
Según los apuntes, ¿que antipatrón es?	Sección 5, Criptografía: Para números aleatorios de seguridad (sal, tokens) usa un generador seguro, no System.Random.
Si fueras un atacante, ¿cómo lo utilizarías?	El token tiene solo 6 cifras, es decir, unas 900.000 posibilidades, y Random es predecible. Puedo probar tokens uno a uno hasta acertar el de otro usuario, o deducir el siguiente a partir de los que ya he visto.
Indica el nivel de gravedad: alto, medio, bajo	Alto

Fallo 6

Línea y fichero en el que está ubicado el error:	AuthService.cs, Línea 49
Según los apuntes, ¿que antipatrón es?	Sección 8: Nunca registres contraseñas, tokens o datos personales.
Si fueras un atacante, ¿cómo lo utilizarías?	Cualquiera que vea la consola o lea los registros obtiene el token de la sesión y puede usarlo como si fuera

	el usuario.
Indica el nivel de gravedad: alto, medio, bajo	Medio

Fallo 7

Línea y fichero en el que está ubicado el error:	Program.cs, líneas 98 (método Registrar) y 109 (método IniciarSesion), donde se lee la contraseña con Console.ReadLine().
Según los apuntes, ¿que antipatrón es?	Sección 3 (Contraseñas).
Si fueras un atacante, ¿cómo lo utilizarías?	Miro por encima del hombro mientras la persona escribe, o veo la contraseña en una captura de pantalla o en una pantalla compartida, y después inicio sesión con su cuenta.
Indica el nivel de gravedad: alto, medio, bajo	Bajo

Fallo 8

Línea y fichero en el que está ubicado el error:	Program.cs, líneas 58-62
Según los apuntes, ¿que antipatrón	Mostrar el error completo al usuario

es?	(tabla de lo que nunca debes hacer y sección 8): al usuario, un mensaje genérico.
Si fueras un atacante, ¿cómo lo utilizarías?	Provoco un fallo a propósito y la traza me enseña nombres de clases, métodos y rutas de ficheros del equipo. Son pistas sobre cómo está hecha la aplicación y dónde atacarla.
Indica el nivel de gravedad: alto, medio, bajo	Medio

Fallo 9

Línea y fichero en el que está ubicado el error:	RedService.cs, líneas 18-22
Según los apuntes, ¿que antipatrón es?	Mostrar el error completo al usuario (sección 8).
Si fueras un atacante, ¿cómo lo utilizarías?	Con la opción 6 ya se ve el error real (por ejemplo, que no se encuentra el servidor api.miapp-insegura.local). Me confirma la dirección y el tipo de servidor al que se conecta la app y me ayuda a preparar un ataque contra él.
Indica el nivel de gravedad: alto, medio, bajo	Medio

Fallo 10

Línea y fichero en el que está ubicado el error:	Program.cs, línea 143
Según los apuntes, ¿que antipatrón es?	Sección 8: Nunca registres contraseñas, tokens o datos personales.
Si fueras un atacante, ¿cómo lo utilizarías?	Si la persona comparte pantalla, hace una captura o alguien mira su monitor, obtengo su token de sesión sin tener que adivinarlo.
Indica el nivel de gravedad: alto, medio, bajo	Medio

PARTE 2 – Corrección de los errores

Siguiendo los apuntes, corrige los errores detectados en el código. Modifica el código de la aplicación entregada.

ENTREGA:

- El código compilado y corregido (recuerda comentar las modificaciones que hayas realizado). Recuerda que la url del código debe de estar pública, sino compártemela directamente a sserrano@ilerna.com • El fichero de la

auditoría realizada

IMPORTANTE:

El uso de la inteligencia artificial para resolver el ejercicio implica la suspensión directa de la actividad i del RA05.